BÁO CÁO KẾT QUẢ THỰC TẬP

Tuần 4:Làm Việc Với Passport, Guard và Role-based Authentication

I. LÝ THUYẾT

1. Hệ thống xác thực Passport và JWT Strategy

1.1. Passport là gì?

- Passport là một thư viện middleware hỗ trợ xác thực người dùng trong ứng dụng Node.js. Thư viện này cung cấp cơ chế xác thực linh hoạt thông qua các chiến lược (Strategy), chẳng hạn như xác thực bằng tên đăng nhập và mật khẩu, JWT hoặc OAuth.
- Trong NestJS, Passport được tích hợp thông qua thư viện `@nestjs/passport`, giúp kết hợp các chiến lược xác thực với hệ thống Guard để bảo vệ API.

1.2. JWT Strategy là gì?

- JWT Strategy là một chiến lược xác thực của Passport, được cung cấp thông qua thư viện `passport-jwt`.
- JWT Strategy có nhiệm vụ trích xuất JWT từ HTTP request, kiểm tra chữ ký số, thời hạn hiệu lực và thực hiện xác thực thông tin trong payload.

2. Cơ chế kiểm soát truy cập dựa trên vai trò

2.1. Role-Based Access Control là gì?

- RBAC (Role-Based Access Control) là cơ chế phân quyền truy cập dựa trên vai trò của người dùng trong hệ thống.
- Mỗi người dùng được gán một vai trò nhất định, ví dụ `ADMIN` hoặc `USER`. Tùy vào vai trò, người dùng chỉ được phép thực hiện các chức năng tương ứng.

2.2. Roles Decorator

- Decorator là cơ chế hỗ trợ gắn metadata vào các class hoặc phương thức trong NestJS.
- Trong hệ thống RBAC, `@Roles()` được sử dụng để khai báo vai trò cần thiết nhằm truy cập một API.

2.3. RolesGuard

- RolesGuard là một lớp bảo vệ có nhiệm vụ kiểm tra vai trò của người dùng trước khi cho phép truy cập vào API.

- RolesGuard đọc metadata từ `@Roles()` và so sánh với vai trò của người dùng đã được xác thực.
- Nếu vai trò phù hợp, yêu cầu được tiếp tục xử lý. Nếu không, hệ thống trả về lỗi 403 `Forbidden`.

II. NỘI DUNG THỰC HÀNH & CÁC CÂU LỆNH CẤU HÌNH

1. Câu lệnh cấu hình

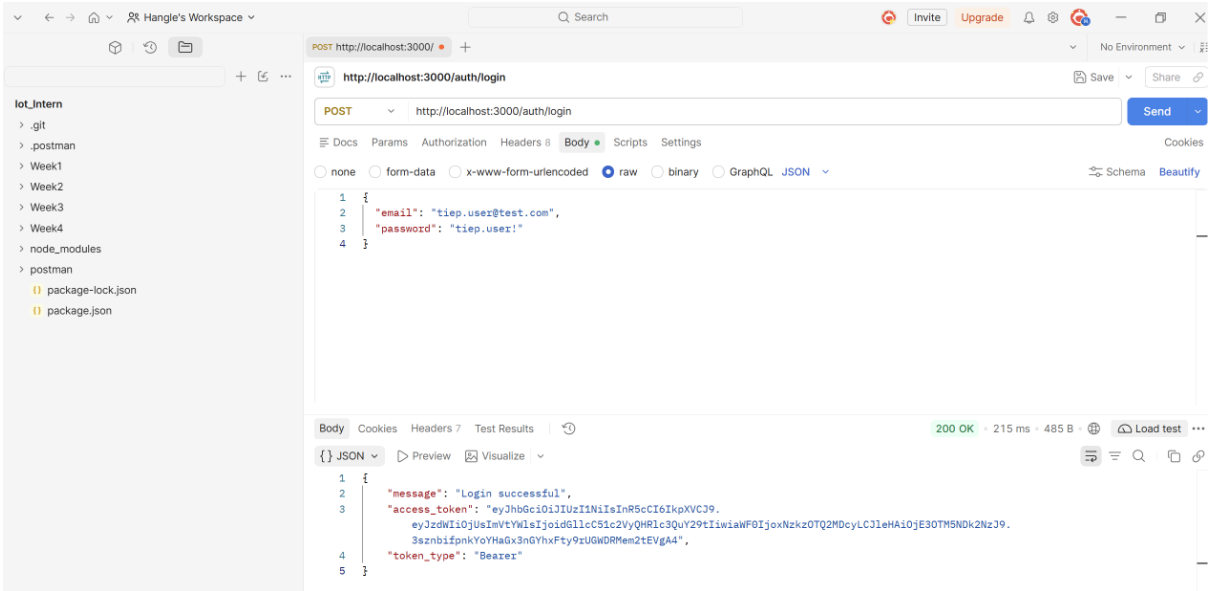
- npm install @nestjs/passport passport passport-jwt @nestjs/jwt
- npm install --save-dev @types/passport-jwt

2.Kết quả kiểm thử hệ thống

LUỒNG 1: QUY TRÌNH XÁC THỰC (AUTHENTICATION)

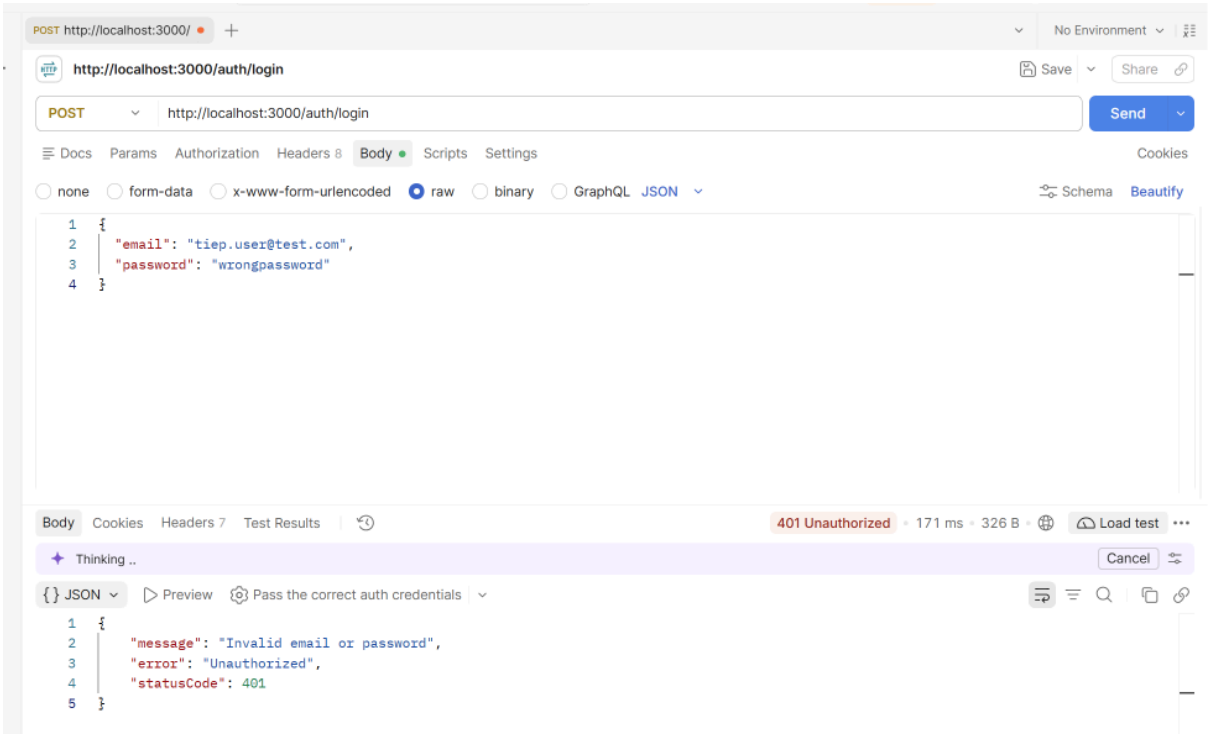
Test 01 – Đăng nhập thành công và lấy JWT

Mô tả : Người dùng gửi email và mật khẩu hợp lệ. Backend xác thực thông tin đăng nhập và sử dụng JwtService để phát hành JWT, phục vụ việc xác thực ở các request tiếp theo.



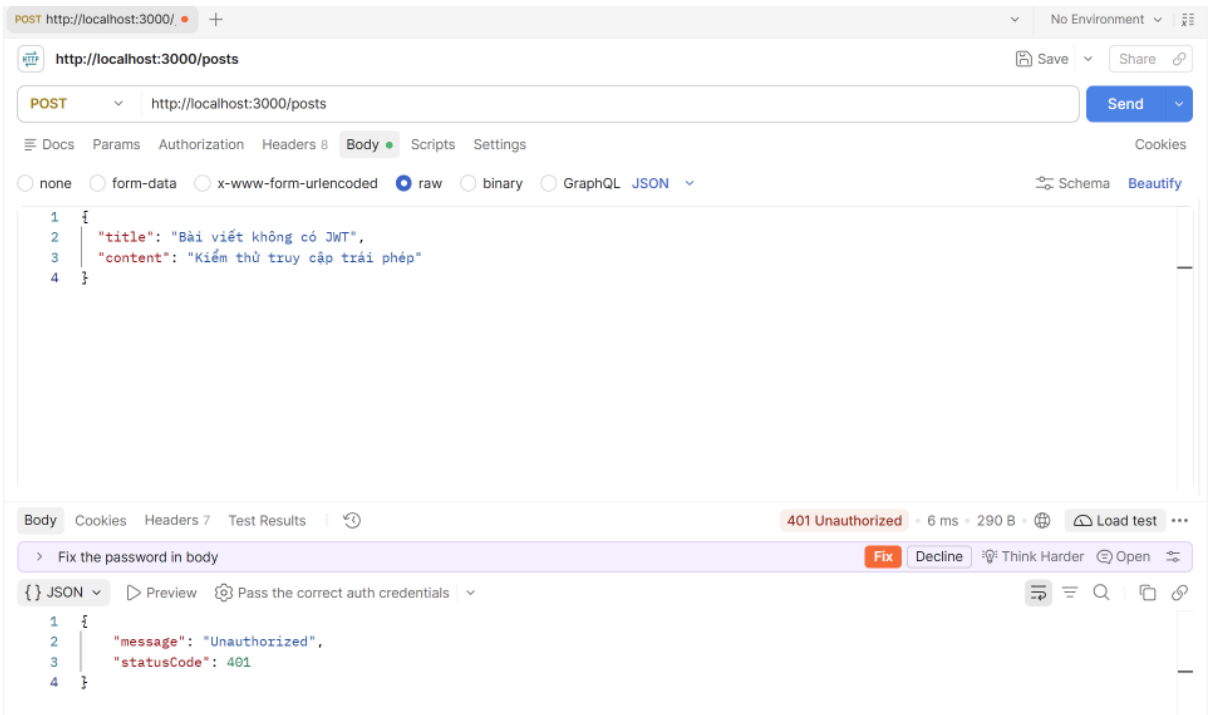
Test 02 – Đăng nhập sai mật khẩu

Mô tả : Server phát hiện mật khẩu không khớp với dữ liệu đã lưu, từ chối đăng nhập và không cấp JWT.



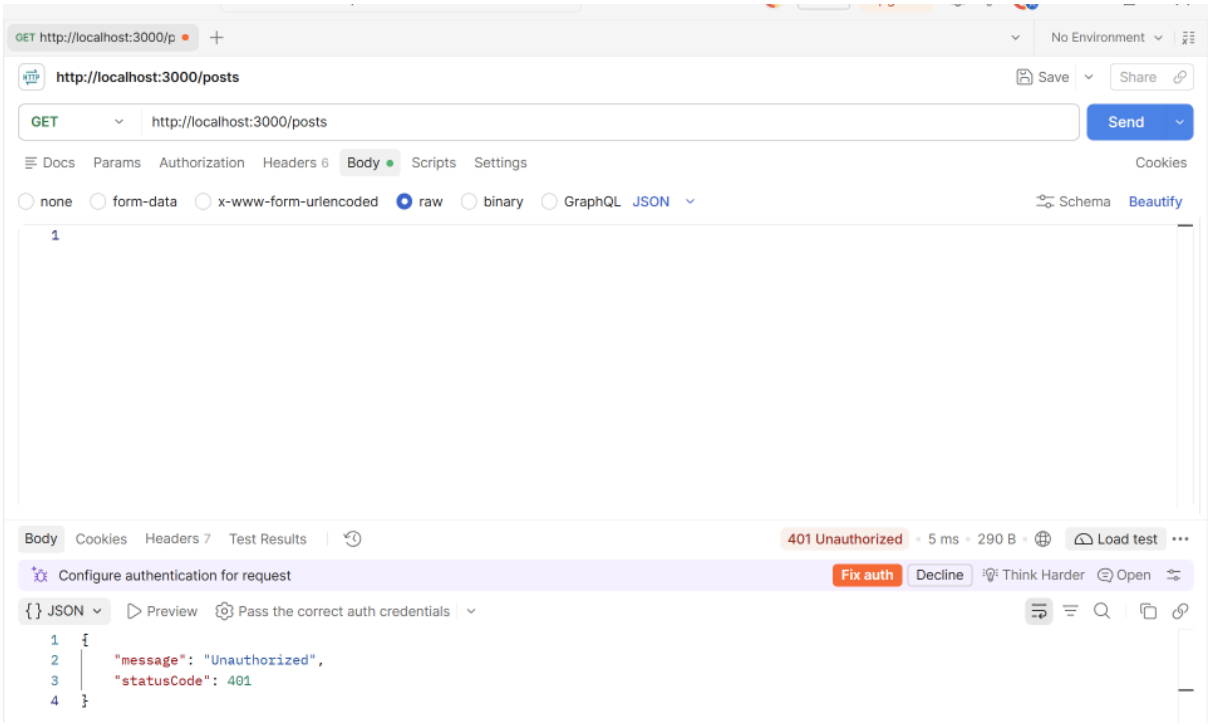
Test 03 – Tạo bài viết không có JWT

Mô tả : Passport JWT Strategy không thể xác minh token không hợp lệ và từ chối quyền truy cập API.



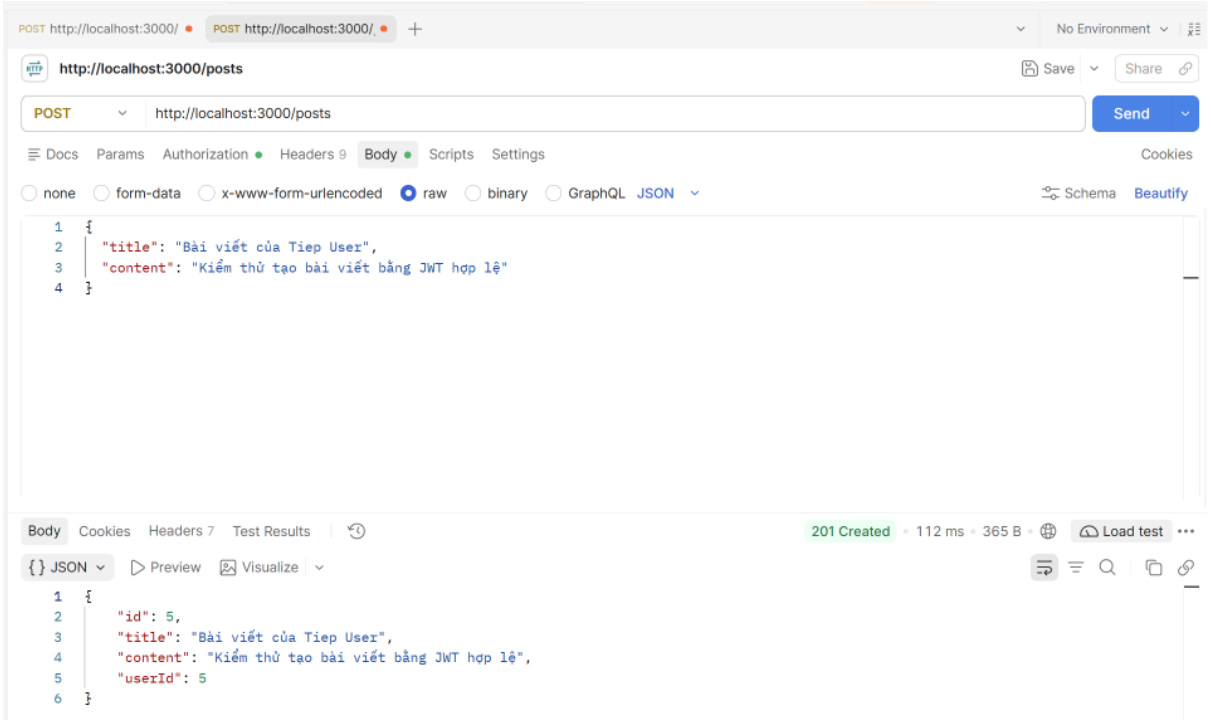
Test 04 – Sử dụng JWT không hợp lệ

Mô tả : Passport JWT Strategy không thể xác minh token không hợp lệ và từ chối quyền truy cập API.



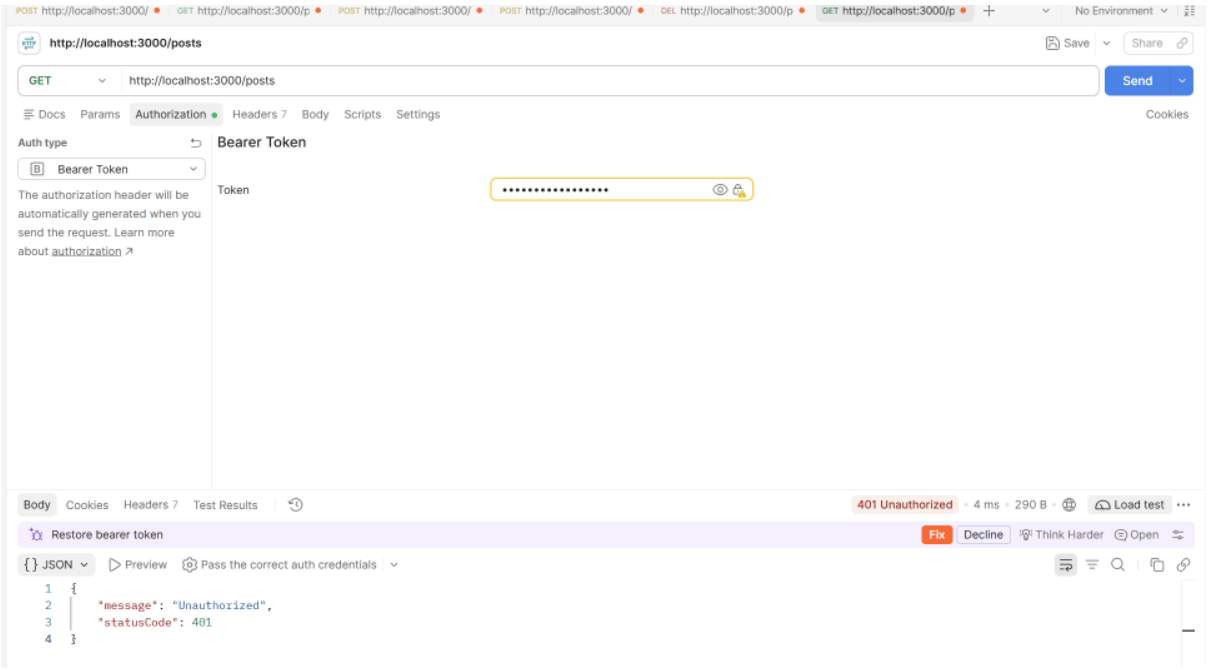
Test 05 – USER tạo bài viết bằng JWT hợp lệ

Mô tả: JWT được xác minh thành công, RolesGuard xác nhận tài khoản USER có quyền tạo bài viết. Controller và Service thực hiện lưu bài viết vào PostgreSQL



Test 06 – JWT hết hạn

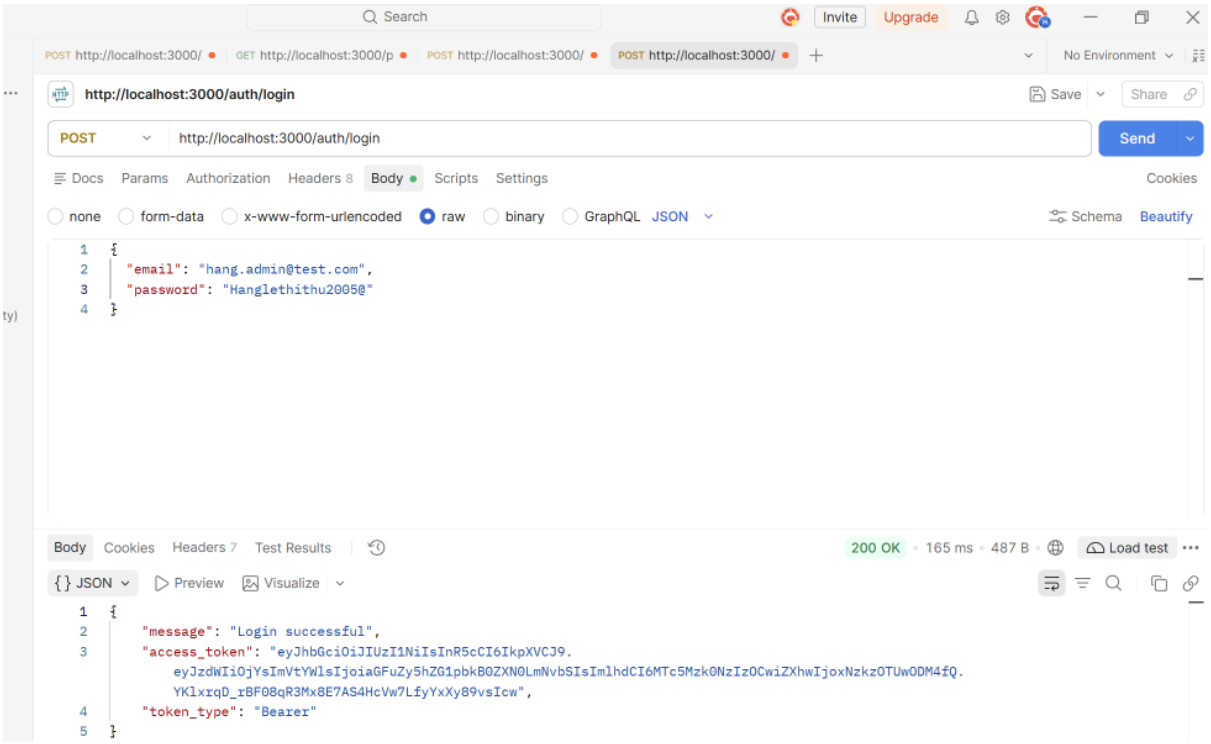
Mô tả: JwtStrategy kiểm tra thời hạn JWT và từ chối token có thời gian hiệu lực đã kết thúc, giúp hạn chế sử dụng lại token cũ



LUỒNG 2: QUY TRÌNH PHÂN QUYỀN (AUTHORIZATION)

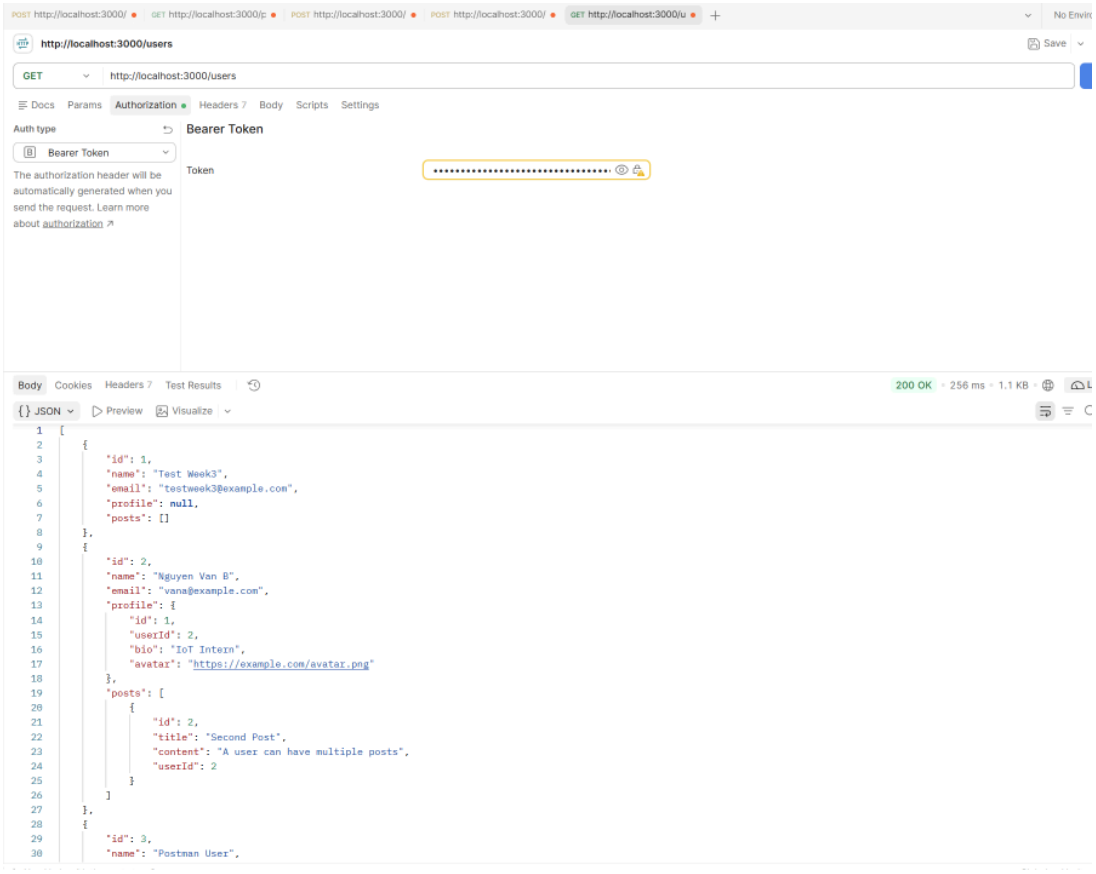
Test 07 – ADMIN đăng nhập lấy JWT

Mô tả báo cáo: Tài khoản có role ADMIN đăng nhập thành công và nhận JWT để thực hiện các chức năng quản trị.



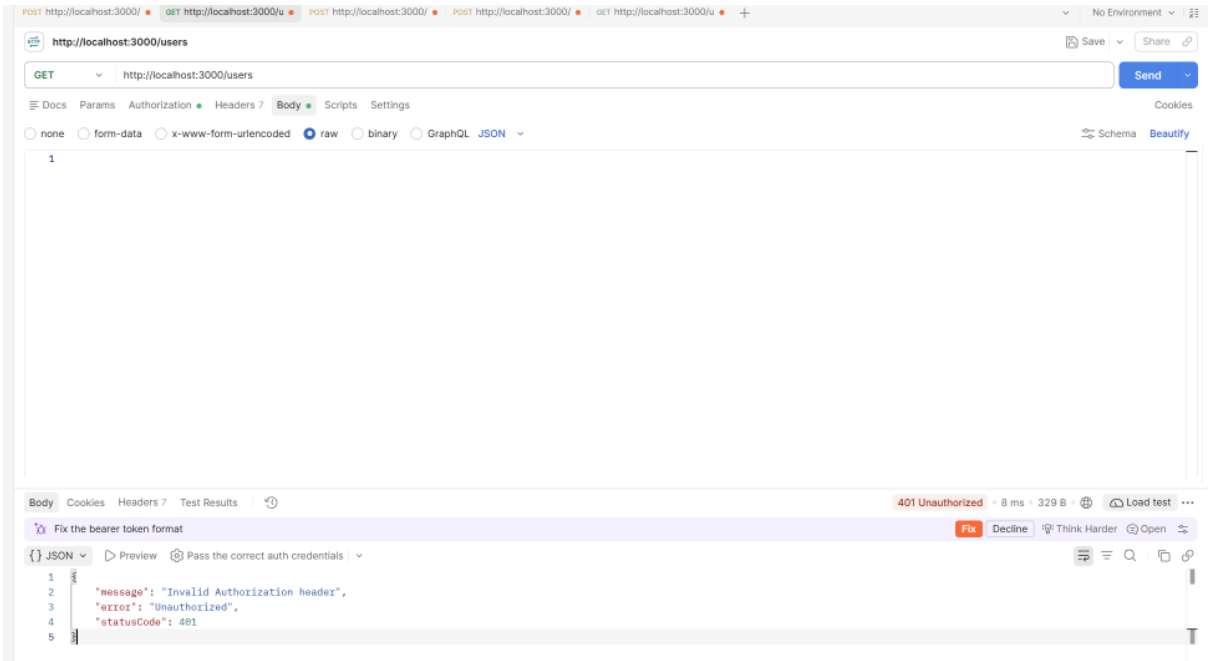
Test 08 – ADMIN truy cập danh sách người dùng

Mô tả : JwtAuthGuard xác thực tài khoản ADMIN; RolesGuard đối chiếu role với metadata `@Roles('ADMIN')` và cho phép truy xuất dữ liệu.



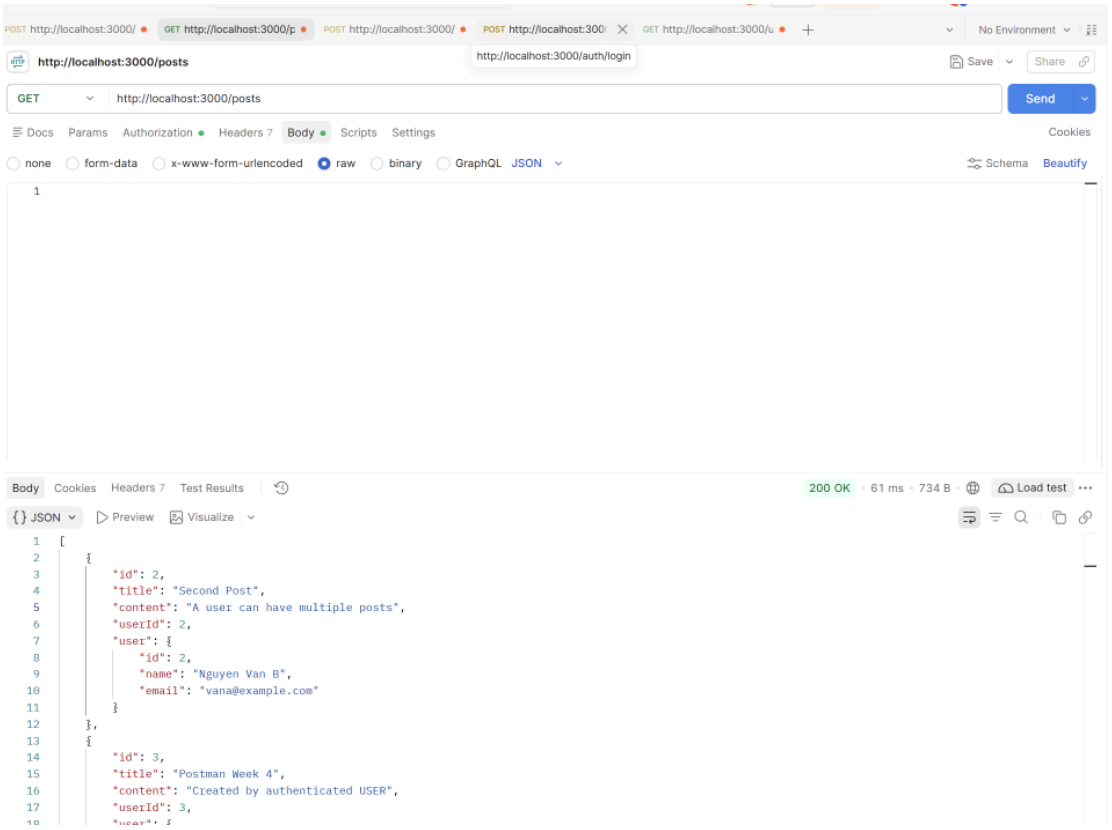
Test 09 – USER truy cập tài nguyên ADMIN

Mô tả: USER được xác thực bằng JWT nhưng không đáp ứng yêu cầu role ADMIN. RolesGuard chặn request, ngăn truy cập dữ liệu quản trị.



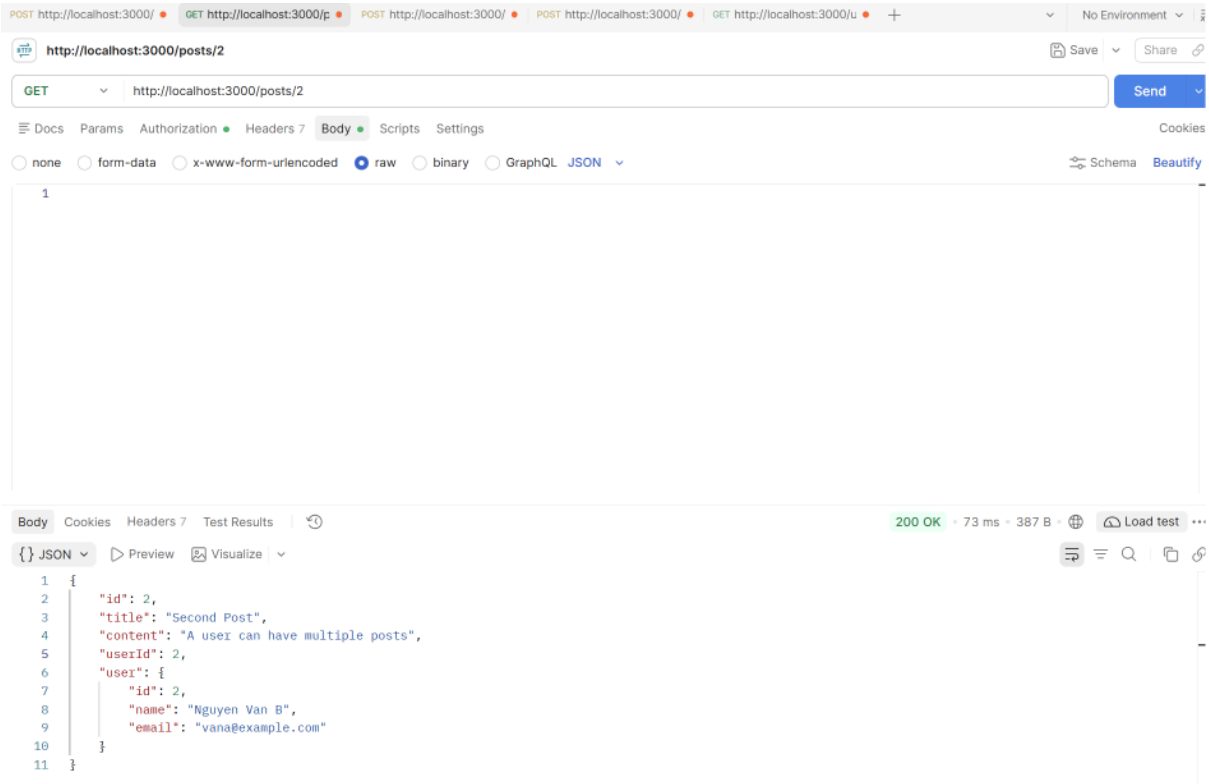
Test 10 – USER đọc danh sách bài viết

Mô tả : Người dùng có role USER được phép đọc danh sách bài viết do endpoint được khai báo cho cả USER và ADMIN.



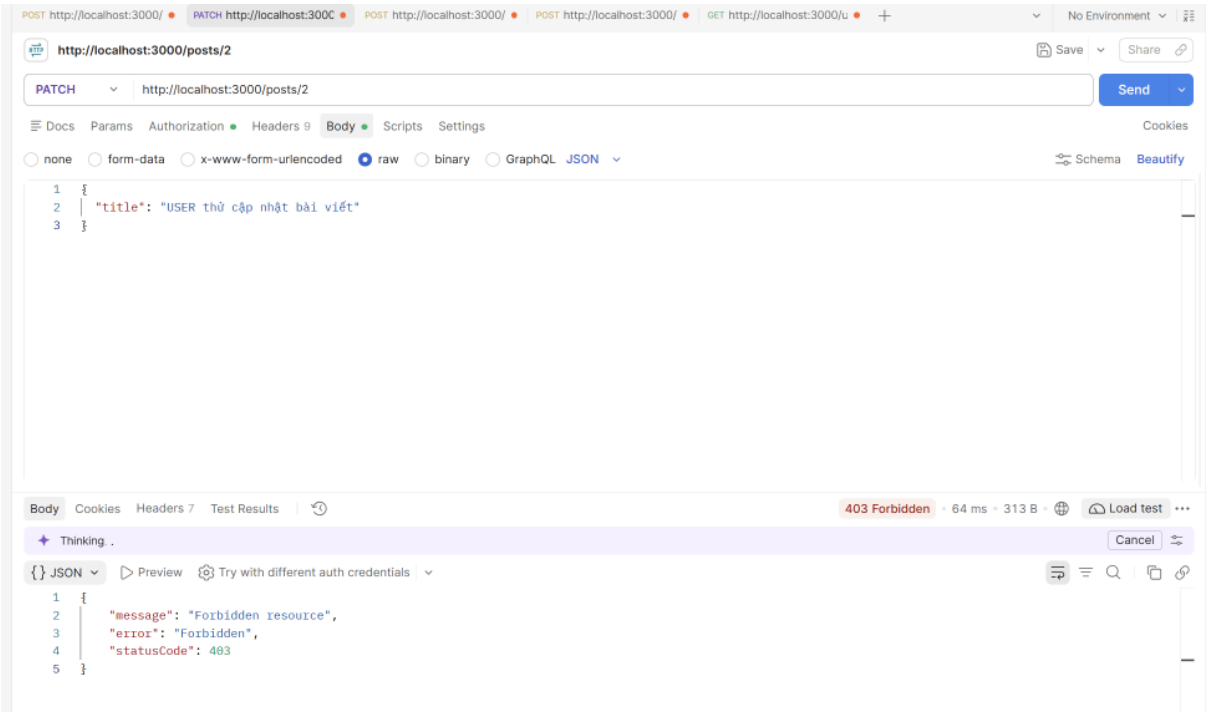
Test 11 – USER đọc chi tiết bài viết

Mô tả : Hệ thống xác thực JWT và cho phép USER đọc nội dung bài viết theo quyền đã cấu hình.



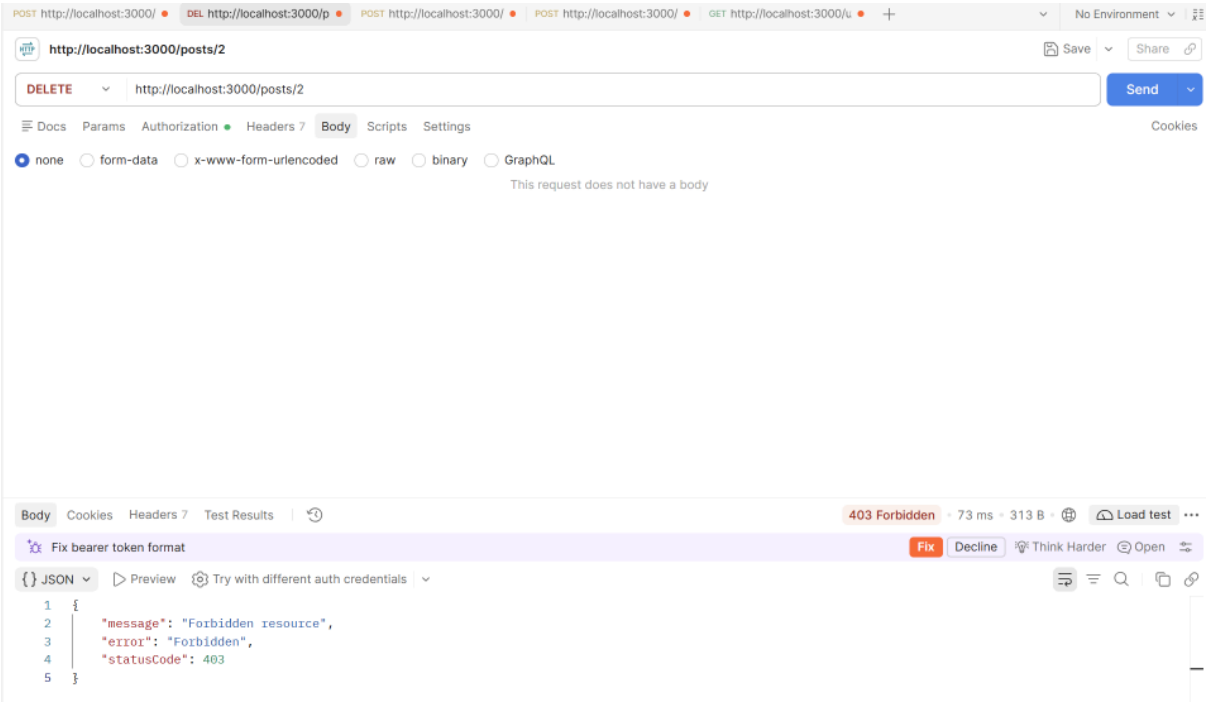
Test 12 – USER cập nhật bài viết

Mô tả: USER không có quyền chỉnh sửa theo quy tắc `@Roles('ADMIN')`. RolesGuard từ chối request trước khi thực thi logic cập nhật.

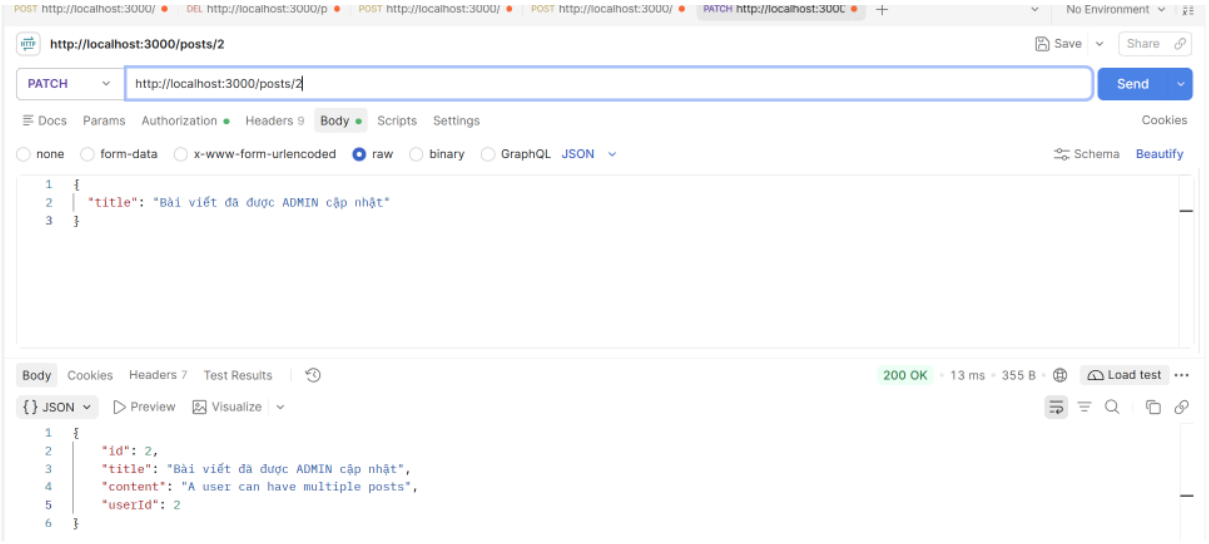


Test 13 – USER xóa bài viết

Mô tả : RolesGuard ngăn tài khoản USER thực hiện chức năng xóa bài viết vì endpoint chỉ dành cho ADMIN.



Test 14 – ADMIN cập nhật bài viết



Test 15 – ADMIN xóa bài viết

Mô tả : Tài khoản ADMIN đáp ứng điều kiện phân quyền, hệ thống cho phép xóa bài viết khỏi database.

